COMPREHENSIVE PENETRATION TESTING & VULNERABILITY ASSESSMENT

CAPSTONE REPORT

Prepared for	RabTech Academy — Cybersecurity & Ethical Hacking
Prepared by	Dhanu Shree
Assessment environment	Simulated training environment
Report version	1.0 | 10 October 2026
Classification	Educational sample — not a real-world assessment

Important: This 16-page report is a training template containing illustrative findings. It does not claim that a real target was tested. Replace sample evidence and scores with verified results from an authorized lab before final mentor review.

1. Executive Summary

This report demonstrates how a penetration testing and Vulnerability Assessment and Penetration Testing (VAPT) engagement can be documented for an executive audience. The example scenario is a simulated web application. The findings below are training examples, not verified vulnerabilities in a live system.

The sample assessment focuses on common web application risk areas: access control, input handling, security configuration, error handling, and authentication safeguards. The objective is to show a repeatable process for prioritizing risk and communicating remediation in plain language.

Illustrative executive view

Measure	Illustrative result	Interpretation
Example findings	5	Sample set for report-writing practice only
High	2	Would require prompt owner review if verified
Medium	3	Should be scheduled based on exposure and business impact
Real target tested	No	No live system was assessed when generating this report

Recommended executive actions

- Confirm written authorization and scope before any real testing.
- Prioritize verified access-control and injection risks because they can expose or alter data.
- Assign remediation owners and dates; retest safely after fixes are deployed.
- Track accepted risks formally and keep evidence free of secrets or personal information.

2. Scope, Authorization & Rules of Engagement

A real assessment must have written permission, named owners, a defined time window, and exact targets. This example assumes an isolated training application and synthetic data. The values below must be replaced with the mentor-approved scope for any actual exercise.

Scope item	Training-template value
Target	Simulated training web application
Environment	Local / isolated sandbox only
Authorization owner	To be completed by learner and mentor
Approved dates	To be completed before testing
Permitted activities	Passive review, manual test cases, configuration review, documentation
Excluded activities	DoS, destructive tests, persistence, phishing, brute force, production data access

Rules of engagement

- Test only systems explicitly listed in the authorization.
- Use test accounts and synthetic records; do not access real user information.
- Stop if unexpected sensitive data or service instability appears.
- Preserve timestamps and redact tokens, passwords, and personal data from screenshots.
- Share findings only with the designated owner or mentor.

3. Methodology

The sample workflow follows a controlled assessment lifecycle. It is designed to keep the work authorized, repeatable, and focused on actionable remediation.

Phase	Activities	Deliverable
1. Plan	Confirm authorization, scope, exclusions, contacts, and test window	Signed scope / rules of engagement
2. Discover	Identify application components and review exposed configuration within scope	Asset and observation notes
3. Assess	Use safe manual checks and approved test cases; avoid destructive actions	Evidence-backed candidate findings
4. Analyze	Map verified issues to OWASP categories and estimate CVSS v3.1	Prioritized findings register
5. Report	Explain impact, evidence, fix, owner, and target date	Executive report and technical details
6. Retest	Repeat minimal safe checks after fixes	Retest results and closure status

Evidence standard

A finding should include a clear title, affected asset, reproducible steps within scope, timestamp, redacted evidence, impact, likelihood rationale, CVSS vector/score, OWASP mapping, remediation, and retest criteria. If evidence is incomplete, label the item as a hypothesis or observation rather than a confirmed vulnerability.

4. Risk Rating & CVSS v3.1

CVSS v3.1 provides a standardized way to describe technical severity. A score should be calculated from verified exploitability and impact facts, not guessed from a title. The illustrative scores in this report are placeholders for learning and must be recalculated for actual findings.

CVSS score	Severity	Typical response guidance
9.0–10.0	Critical	Immediate containment and urgent remediation
7.0–8.9	High	Prioritize quickly; commonly within days
4.0–6.9	Medium	Schedule remediation based on risk and exposure
0.1–3.9	Low	Address through planned maintenance
0.0	None	No CVSS base severity assigned

Risk decisions should also consider business context: data sensitivity, internet exposure, compensating controls, active exploitation, affected user population, and operational criticality. CVSS is one input to prioritization, not a complete business-risk decision.

Scoring note

The sample findings register uses illustrative scores to demonstrate report layout. Use the official FIRST CVSS v3.1 calculator and record the complete vector string when scoring a verified issue.

5. Findings Overview & Prioritization

ID	Illustrative finding	OWASP 2021 mapping	CVSS	Severity
F-01	Missing/weak security headers	A05 Security Misconfiguration	5.3	Medium
F-02	Insufficient server-side input validation	A03 Injection	8.1	High
F-03	Inconsistent authorization checks	A01 Broken Access Control	8.1	High
F-04	Overly detailed error responses	A05 Security Misconfiguration	4.3	Medium
F-05	Authentication controls need review	A07 Identification and Authentication Failures	6.5	Medium

These entries are simulated examples and should not be interpreted as confirmed defects in any named service. Prioritization assumes the scenarios are later verified in a controlled lab.

Suggested order

- First: verify and address any confirmed access-control bypass or injection risk.
- Next: review authentication protections and password-reset flows.
- Then: correct response headers and error handling as part of secure configuration.
- For each issue, document the affected route or component without exposing sensitive data.

F-01. Missing or Weak Security Headers

OWASP mapping: A05:2021 — Security Misconfiguration **Illustrative CVSS:** 5.3 / Medium

Description and evidence status

Illustrative scenario: a sample application response does not include one or more headers appropriate to its content and deployment. This is an observation to review, not proof of an exploit.

Safe validation approach

- Review response headers using a single passive request to an authorized host.
- Compare the current policy with application needs and browser compatibility.
- Check whether framing restrictions and content-type handling are already implemented by other controls.

Recommended remediation

- Set a Content-Security-Policy appropriate to application resources and test it in report-only mode first where suitable.
- Enable X-Content-Type-Options: nosniff.
- Set a suitable Referrer-Policy and framing protection (CSP frame-ancestors or X-Frame-Options where needed).
- Use HSTS only after confirming HTTPS coverage and deployment readiness.

Retest acceptance criteria: Retest: inspect the response, verify policy values are intentional, and confirm core pages and integrations still work.

Evidence status: simulated training example; replace with actual redacted evidence and a recalculated CVSS vector after authorized verification.

F-02. Insufficient Server-Side Input Validation

OWASP mapping: A03:2021 — Injection **Illustrative CVSS:** 8.1 / High

Description and evidence status

Illustrative scenario: a server-side data access path may build queries or commands unsafely from user-controlled values. No live exploit was run to produce this report.

Safe validation approach

- Review source code and approved test cases in an isolated lab.
- Verify whether data access uses parameterized queries or safe ORM methods.
- Use harmless synthetic inputs and stop if test activity could modify or expose real data.

Recommended remediation

- Replace string-concatenated queries with parameterized queries.
- Apply server-side allowlist validation where appropriate; encode output for its destination context.
- Use least-privileged database accounts and avoid exposing detailed database errors.
- Add regression tests for boundary and malformed inputs.

Retest acceptance criteria: Retest: confirm input is handled as data, not executable query syntax; verify legitimate workflows still work.

Evidence status: simulated training example; replace with actual redacted evidence and a recalculated CVSS vector after authorized verification.

F-03. Inconsistent Authorization Checks

OWASP mapping: A01:2021 — Broken Access Control **Illustrative CVSS:** 8.1 / High

Description and evidence status

Illustrative scenario: a role or object-level access rule may not be consistently enforced across endpoints. This is a hypothetical training case, not a confirmed bypass.

Safe validation approach

- Use approved test accounts with different roles and synthetic records.
- Create an access matrix listing roles, actions, and permitted resources.
- Test server-side enforcement only on explicitly authorized routes.

Recommended remediation

- Enforce authorization on every server-side request and object access.
- Deny by default and centralize policy checks where practical.
- Avoid relying on hidden buttons or client-side checks as access controls.
- Add automated tests for role boundaries and object ownership.

Retest acceptance criteria: Retest: unauthorized role/action combinations must return a safe denial and must not disclose protected records.

Evidence status: simulated training example; replace with actual redacted evidence and a recalculated CVSS vector after authorized verification.

F-04. Overly Detailed Error Responses

OWASP mapping: A05:2021 — Security Misconfiguration **Illustrative CVSS:** 4.3 / Medium

Description and evidence status

Illustrative scenario: error pages may reveal stack traces, framework details, file paths, or internal identifiers. The report does not contain real application evidence.

Safe validation approach

- Review controlled invalid-input and error cases in the lab.
- Compare client-facing messages with protected server logs.
- Check that error pages do not include secrets or personal data.

Recommended remediation

- Return generic error messages to clients and use a correlation ID for support.
- Keep diagnostic details in access-controlled logs with retention limits.
- Ensure logging itself does not record passwords, tokens, or session cookies.
- Add tests for common error paths.

Retest acceptance criteria: Retest: client responses should be informative enough for users but not disclose internal implementation details.

Evidence status: simulated training example; replace with actual redacted evidence and a recalculated CVSS vector after authorized verification.

F-05. Authentication Controls Need Review

OWASP mapping: A07:2021 — Identification and Authentication Failures **Illustrative CVSS:** 6.5 / Medium

Description and evidence status

Illustrative scenario: password storage, login throttling, session lifecycle, or account recovery protections require review. No real accounts were tested.

Safe validation approach

- Review design and configuration without attempting credential stuffing or brute force.
- Confirm password hashes are stored using a suitable password-hashing function.
- Inspect session invalidation and password-reset token lifecycle in a test account.

Recommended remediation

- Use bcrypt or Argon2id with an appropriate cost and unique salt.
- Apply rate limiting and risk-based safeguards to authentication and recovery endpoints.
- Use MFA where appropriate and secure reset tokens with expiry and single-use rules.
- Invalidate sessions after password reset and protect cookies with Secure, HttpOnly, and appropriate SameSite attributes.

Retest acceptance criteria: Retest: confirm correct credentials work, incorrect attempts are safely throttled, reset tokens expire, and sessions are invalidated as designed.

Evidence status: simulated training example; replace with actual redacted evidence and a recalculated CVSS vector after authorized verification.

11. OWASP Top 10 Mapping

OWASP Top 10 is an awareness document describing broad web application risk categories. The mapping below is illustrative and should be confirmed against the specific root cause of each verified issue.

OWASP Top 10:2021 category	Relevant example in this report	Notes
A01 Broken Access Control	F-03	Use only when authorization enforcement is the root cause.
A03 Injection	F-02	Map when untrusted input can influence an interpreter or query.
A05 Security Misconfiguration	F-01, F-04	Header and error-handling observations may fit here.
A07 Identification and Authentication Failures	F-05	Use for authentication/session weaknesses when verified.
Other categories	Not assessed here	Absence from this sample does not imply absence of risk.

A vulnerability may span categories. Record the category that best explains the root cause and document any secondary relationships in the technical notes.

12. Remediation Roadmap

Priority	Target planning window	Actions	Suggested owner
Critical	Immediate / 24 hours	Contain confirmed active exposure; disable affected path if necessary; rotate exposed secrets	System owner + security
High	Within 7 days	Fix verified access-control or injection flaws; add regression tests	Application team
Medium	Within 30 days	Improve configuration, authentication safeguards, and error handling	Development / operations
Low	Within 90 days	Improve documentation, defense-in-depth, and monitoring	Product owner

These are suggested planning targets, not universal service-level agreements. The system owner should set dates according to exposure, exploitability, business impact, dependencies, and policy.

Governance actions

- Assign one accountable owner per finding.
- Track status as Open, In Progress, Fixed, Accepted Risk, or Unable to Verify.
- Record risk acceptance with an approver, rationale, compensating controls, and expiry/review date.
- Retest after deployment and keep a record of the outcome.

13. Retesting & Closure Criteria

Retesting confirms whether the original weakness was corrected without introducing a new problem. It should use the smallest safe test that proves the acceptance criteria.

Finding type	Retest criteria
Security headers	Expected headers and values are present and appropriate; page functionality remains intact.
Input handling	Untrusted values are handled as data; regression tests pass; no unsafe query construction remains.
Access control	Unauthorized role/object combinations are denied server-side without data leakage.
Error handling	Client responses avoid internal details; protected logs retain useful diagnostics without secrets.
Authentication	Password hashing, throttling, reset-token expiry, and session invalidation behave as intended.

Evidence checklist

- Record test date, environment, tester, and version/build.
- Save screenshots or sanitized logs only when needed; redact credentials and personal data.
- Document pass/fail and any limitations.
- Close a finding only when its acceptance criteria are met or a risk owner formally accepts it.

14. Limitations, Assumptions & Disclosure

This document was generated as a sample capstone report using simulated findings. No live website, organization, production server, or user account was assessed during preparation. Therefore, the findings, evidence descriptions, scores, and remediation priorities are illustrative.

Assumptions

- A controlled lab will be used for any practical verification.
- Written permission and a defined scope will be obtained before testing.
- The learner will replace sample content with truthful results from approved exercises.
- The mentor or system owner will review final severity scores and remediation plans.

Limitations

- This is not a compliance certification or guarantee of security.
- A passive header check cannot establish whether an application is vulnerable overall.
- CVSS base scores do not capture every business or environmental risk factor.
- The example does not include a complete source-code review, infrastructure assessment, or production validation.

Responsible disclosure

Report real findings privately to the authorized owner. Do not publish exploit details, personal information, credentials, or screenshots that expose sensitive data. Follow the organization's disclosure and incident-response process.

15. Conclusion, References & Submission Checklist

A useful VAPT report connects technical observations to business risk and gives the owner clear next steps. This capstone demonstrates report structure, sample OWASP mapping, CVSS-based prioritization, remediation planning, and retesting. The next step is to replace the simulated examples with verified results from an authorized training environment.

References

- OWASP Top 10:2021 — https://owasp.org/Top10/
- FIRST CVSS v3.1 Specification — https://www.first.org/cvss/v3.1/specification-document
- NIST SP 800-115, Technical Guide to Information Security Testing and Assessment — https://csrc.nist.gov/pubs/sp/800/115/final
- OWASP Web Security Testing Guide — https://owasp.org/www-project-web-security-testing-guide/

Before submission

- Confirm the report is 15–20 pages and review the PDF after download.
- Upload the PDF and the GitHub security lab repository to a public repository, without secrets.
- Replace all simulated evidence and scores if you performed an actual authorized assessment.
- Submit one public GitHub repository URL in RabTech Academy; include the PDF inside the repo.
- Check that the repository contains README, scope/rules of engagement, findings register, remediation plan, retest checklist, and passive checker script.

Final note: The academy page expects a formal VAPT report PDF (15–20 pages) plus a GitHub Security Lab Repo. A PDF by itself may not satisfy both requirements.